

Detecção e Mitigação de Ransomware

1. Regra YARA

```
rule Academic_Ransomware_Detector
{
    meta:
        description = "Detecta amostras de ransomware acadêmico com OpenSSL e extensão .locked"
        author = "OpenAI"
        date = "2026-04-23"
        category = "ransomware"

    strings:
        $ext = ".locked"
        $rsa = "RSA_PKCS1_OAEP_PADDING"
        $aes = "EVP_aes_256_cbc"
        $pem = "publica.pem"
        $seed = "bm90bm90cGV0eWE="
        $curl = "curl_easy_perform"
        $rand = "RAND_bytes"

    condition:
        4 of them
}
```

2. Regra Sigma

```
title: Possible Ransomware File Encryption Activity
id: 3e7a5f14-7e14-4ef8-9e16-ransomware-demo
status: experimental
description: Detecta comportamento típico de ransomware com criação massiva de arquivos e exclusão dos originais
author: OpenAI
date: 2026/04/23
logsource:
    product: windows
    category: file_event

detection:
    selection_ext:
        TargetFilename|endswith: '.locked'
```

```
condition: selection_ext

falsepositives:
- Ferramentas legítimas de criptografia
level: high
```

3. Regra Sigma para Processo

```
title: Suspicious Mass File Encryption Behavior
id: a8c3d9b2-1f32-4cb7-bd82-ransomware-process
status: experimental
logsource:
  product: windows
  category: process_creation

detection:
  selection:
    Image|contains:
      - 'openssl'
      - 'curl'

  condition: selection

falsepositives:
- Ferramentas administrativas legítimas
level: medium
```

4. Regras de Detecção para SIEM

Splunk SPL

```
index=filesystem (file_name="*.locked")
| stats count by host, process_name
| where count > 20
```

Microsoft Sentinel (KQL)

```
DeviceFileEvents
| where FileName endswith ".locked"
```

```
| summarize Count=count() by DeviceName, InitiatingProcessFileName,  
bin(Timestamp, 5m)  
| where Count > 20
```

5. Regra Suricata

```
alert http any any -> any 8080 (  
  msg:"Possible Ransomware Key Exfiltration";  
  flow:established,to_server;  
  content:"POST"; http_method;  
  content:"application/json"; http_header;  
  content:"\"hex\":"; http_client_body;  
  content:"\"iv\":"; http_client_body;  
  classtype:trojan-activity;  
  sid:1000001;  
  rev:1;  
)
```

6. Script Python de Monitoramento em Tempo Real

```
import time  
from watchdog.observers import Observer  
from watchdog.events import FileSystemEventHandler  
  
class RansomwareDetector(FileSystemEventHandler):  
    def __init__(self):  
        self.locked_count = 0  
        self.start_time = time.time()  
  
    def on_created(self, event):  
        if event.is_directory:  
            return  
  
        if event.src_path.endswith('.locked'):  
            self.locked_count += 1  
            print(f'[ALERTA] Arquivo criptografado detectado: {event.src_path}')  
  
        elapsed = time.time() - self.start_time  
        if elapsed <= 60 and self.locked_count >= 10:  
            print('[CRÍTICO] Possível ataque de ransomware em andamento!')
```

```
if __name__ == '__main__':  
    path = '.'  
    event_handler = RansomwareDetector()  
    observer = Observer()  
    observer.schedule(event_handler, path, recursive=True)  
    observer.start()  
  
    try:  
        while True:  
            time.sleep(1)  
    except KeyboardInterrupt:  
        observer.stop()  
  
    observer.join()
```

7. Lógica de Detecção para EDR

Cadeia comportamental suspeita

1. Uso de API criptográfica (`RAND_bytes` , `EVP_EncryptInit_ex`)
2. Enumeração recursiva de diretórios
3. Escrita de múltiplos arquivos com nova extensão
4. Exclusão imediata dos arquivos originais
5. Comunicação de saída para domínio externo

Pontuação sugerida

- Geração de chave criptográfica: +20
- Modificação de mais de 20 arquivos em 1 minuto: +30
- Exclusão em massa: +25
- Comunicação com domínio DGA: +35
- POST contendo material criptográfico: +40

Acionar contenção automática se score >= 70

8. Estratégias de Resposta Automática

- Isolar o host da rede
 - Suspende o processo responsável
 - Bloquear hash do executável
 - Encerrar conexões de rede ativas
 - Preservar dump de memória para análise forense
 - Criar snapshot dos arquivos afetados
-

9. Indicadores de Comprometimento (IOCs)

Arquivos

- Extensão: `.locked`
- Arquivo de chave pública: `publica.pem`

Strings

- `RSA_PKCS1_OAEP_PADDING`
- `EVP_aes_256_cbc`
- `bm90bm90cGV0eWE=`
- `curl_easy_perform`

Rede

- HTTP POST para porta 8080
 - JSON contendo campos `hex` e `iv`
 - Domínios gerados por DGA
-

10. Hardening Recomendado

- Implementar allowlisting de aplicações
 - Restringir execução em diretórios de usuário
 - Bloquear ferramentas não autorizadas de criptografia
 - Habilitar proteção contra ransomware no endpoint
 - Utilizar backups offline e imutáveis
 - Monitorar criação massiva de arquivos renomeados
-

11. Playbook de Resposta a Incidentes

1. Detectar atividade suspeita
2. Isolar máquina afetada
3. Identificar processo responsável
4. Coletar artefatos (memória, logs, binário)
5. Verificar extensão do impacto
6. Restaurar a partir de backup confiável
7. Rotacionar credenciais, se necessário
8. Atualizar regras de detecção
9. Realizar lições aprendidas